# Multi-SIEM Detection Content

CVE-2026-109618 · php2shell — PHP RCE via Session Upload Progress Abuse

Platforms: IBM QRadar · Micro Focus ArcSight · Microsoft Sentinel · Palo Alto Cortex XDR · Sigma

---

## IOC Quick Reference

| Indicator | Hardcoded Value | Field / Location |
|---|---|---|
| User-Agent | php2shell-109618 | HTTP Request Header |
| Multipart Boundary | B7kQpoc618 | Content-Type / Request Body |
| Session Field | PHP_SESSION_UPLOAD_PROGRESS | POST Body |
| Spray Parameter | t[] × 149 | POST Body |
| Min POST Size to .php | > 500 KB | Access Log bytes |
| Exploitation Marker | JACKALPOC / uid=0 | HTTP Response Body |

## QRadar

Use AQL (Ariel Query Language) in the Log Activity search tab or as a Saved Search pinned to the Dashboard. For automated alerting, wrap each query in a Custom Rule (CRE).

### QRadar Detection 1 — Exact User-Agent (Critical)

*Matches the hardcoded PoC User-Agent string. Zero false positives expected.*

```
SELECT sourceip, destinationip, URL, "User-Agent", devicetime
FROM events
WHERE LOGSOURCETYPENAME(devicetype) ILIKE '%apache%'
OR LOGSOURCETYPENAME(devicetype) ILIKE '%nginx%'
AND "User-Agent" ILIKE '%php2shell-109618%'
LAST 24 HOURS
```

### QRadar Detection 2 — Multipart Boundary

*Matches the hardcoded boundary in Content-Type or raw request field.*

```
SELECT sourceip, destinationip, URL, "Content-Type", devicetime
FROM events
WHERE "Content-Type" ILIKE '%B7kQpoc618%'
OR UTF8(payload) ILIKE '%B7kQpoc618%'
LAST 24 HOURS
```

### QRadar Detection 3 — Large POST to PHP (Anomaly)

*Tune bytesIn threshold against your environment baseline.*

```
SELECT sourceip, destinationip, URL, bytesIn, devicetime
FROM events
WHERE "Request Method" = 'POST'
AND URL ILIKE '%.php%'
AND bytesIn > 500000
LAST 1 HOURS
```

### QRadar CRE Rule Logic (Event Rule)

*Create a Custom Rule with these conditions (AND logic):*

```
when any of the following event(s) are detected:
"User-Agent" contains 'php2shell-109618'
OR "Content-Type" contains 'B7kQpoc618'
OR (Request Method is 'POST'
AND URL contains '.php'
AND BytesIn > 500000)
Ensure Log Source: Apache / Nginx / IIS
Assign Offense: Yes Severity: High Credibility: 10
```

## ArcSight

Use ArcSight Query Viewer (AQL-like) or build an Active Channel / Correlation Rule in ESM. Field names follow the CEF standard.

### ArcSight Filter 1 — User-Agent Match

*Apply in Active Channel or as a condition in a Correlation Rule.*

```
requestClientApplication CONTAINS 'php2shell-109618'
```

### ArcSight Filter 2 — Boundary Match

```
request CONTAINS 'B7kQpoc618'
OR deviceCustomString1 CONTAINS 'B7kQpoc618'
```

### ArcSight Filter 3 — Large POST to PHP

```
requestMethod = 'POST'
AND requestUrl CONTAINS '.php'
AND bytesIn > 500000
```

### ArcSight Correlation Rule (Velocity / Threshold)

*Combine filters using OR; fire on first match within 5-minute window.*

```
Rule Name : CVE-2026-109618 php2shell Exploit
Conditions:
( requestClientApplication CONTAINS 'php2shell-109618' )
OR ( request CONTAINS 'B7kQpoc618' )
OR ( requestMethod='POST' AND requestUrl CONTAINS '.php'
AND bytesIn > 500000 )
Actions : Set Field 'CVE' = 'CVE-2026-109618'
Create Case / Send Notification
Severity : High
Threshold: 1 event in 300 seconds
```

## Microsoft Sentinel

Use KQL (Kusto Query Language). Deploy as an Analytics Rule in Sentinel. Adjust table names to match your data connectors (CommonSecurityLog, W3CIISLog, etc.).

### Sentinel Detection 1 — User-Agent (CommonSecurityLog / CEF)

*Works when web traffic is forwarded via Syslog/CEF connector.*

```
CommonSecurityLog
| where TimeGenerated > ago(1h)
| where RequestClientApplication has "php2shell-109618"
| project TimeGenerated, SourceIP, DestinationIP,
RequestURL, RequestClientApplication,
AdditionalExtensions
| sort by TimeGenerated desc
```

### Sentinel Detection 2 — IIS/W3C Logs (W3CIISLog)

*Use when IIS logs are ingested directly.*

```
W3CIISLog
| where TimeGenerated > ago(1h)
| where csUserAgent has "php2shell-109618"
or csHost has "B7kQpoc618"
or csBytes > 500000 and csMethod == "POST"
and csUriStem endswith ".php"
| project TimeGenerated, cIP, csUriStem, csMethod,
csUserAgent, csBytes, scStatus
| sort by TimeGenerated desc
```

### Sentinel Detection 3 — Combined High-Fidelity (Analytics Rule)

*Paste into the Analytics Rule query editor. Set frequency: 5 min, lookback: 1 h.*

```
let ua_ioc = "php2shell-109618";
let boundary_ioc = "B7kQpoc618";
let post_size = 500000;
CommonSecurityLog
| where TimeGenerated > ago(1h)
| extend Indicator = case(
RequestClientApplication has ua_ioc, "UA_Match",
AdditionalExtensions has boundary_ioc, "Boundary_Match",
RequestMethod == "POST"
and RequestURL endswith ".php"
and RequestContext > post_size, "Large_PHP_POST",
"")
| where isnotempty(Indicator)
| summarize Count=count(), Indicators=make_set(Indicator),
Targets=make_set(RequestURL)
by SourceIP, bin(TimeGenerated, 5m)
| sort by TimeGenerated desc
```

### Sentinel Watchlist / TI Integration

*Add attacker IPs to a Watchlist for cross-query correlation:*

```
// After alert fires, push src IP to Watchlist
_GetWatchlist('BlockedIPs')
| union (
CommonSecurityLog
| where RequestClientApplication has "php2shell-109618"
| distinct SourceIP
| project SearchKey=SourceIP, ThreatType="CVE-2026-109618"
)
```

## Cortex XDR

Use XQL (Extended Query Language) in the Investigation > XQL Query tab. Create a Correlation Rule to automate alerting.

### Cortex XDR Detection 1 — User-Agent (XQL)

*Query the xdr_data dataset for HTTP events.*

```
dataset = xdr_data
| filter event_type = "STORY"
and http_user_agent ~= "php2shell-109618"
| fields _time, src_ip, dst_ip, http_url,
http_user_agent, http_method,
http_response_code
| sort desc _time
```

### Cortex XDR Detection 2 — Boundary Match (XQL)

```
dataset = xdr_data
| filter http_content_type ~= "B7kQpoc618"
or http_request_body ~= "B7kQpoc618"
| fields _time, src_ip, dst_ip, http_url,
http_content_type, http_method
| sort desc _time
```

### Cortex XDR Detection 3 — Large POST to PHP (XQL)

```
dataset = xdr_data
| filter http_method = "POST"
and http_url ~= "\.php"
and http_request_body_len > 500000
| fields _time, src_ip, dst_ip, http_url,
http_request_body_len, http_response_code
| sort desc _time
```

### Cortex XDR Correlation Rule

*Navigate to Correlation Rules > New Rule and configure:*

```
Name : CVE-2026-109618 php2shell Exploit
Dataset : xdr_data
Filter :
http_user_agent ~= "php2shell-109618"
OR http_content_type ~= "B7kQpoc618"
OR (http_method = "POST"
AND http_url ~= "\.php"
AND http_request_body_len > 500000)
Severity : High
MITRE : T1190 (Exploit Public-Facing Application)
Action : Trigger Alert + Isolate Endpoint (optional)
```

## Sigma Rule

Sigma is a generic, vendor-neutral detection format. Convert to your SIEM's native language using sigma-cli: **sigma convert -t splunk -p sysmon rule.yml**

### sigma_cve_2026_109618_php2shell.yml — Primary Rule (webserver log source)

*Covers User-Agent, boundary and large-POST indicators. Level: critical for first two conditions.*

```
title: CVE-2026-109618 PHP2Shell Exploit Attempt
id: a7f3c1d2-8b4e-4f9a-bc72-0e5d61234567
status: stable
description: Detects RCE exploitation via PHP session upload progress
abuse (CVE-2026-109618). Indicators include a hardcoded User-Agent,
multipart boundary, and large POST body to PHP endpoints.
references:
- https://github.com/eness/php2shell-CVE-2026-109618-CVE-2026-109619-PoC
author: Detection Engineering
date: 2026/10/22
tags:
- attack.initial_access
- attack.execution
- attack.t1190
- cve.2026.109618
logsource:
category: webserver
detection:
selection_ua:
c-useragent|contains: 'php2shell-109618'
selection_boundary:
cs-Content-Type|contains: 'B7kQpoc618'
selection_large_post:
cs-method: 'POST'
cs-uri-stem|endswith: '.php'
sc-bytes|gt: 500000
condition: selection_ua or selection_boundary or selection_large_post
falsepositives:
- None expected for UA and boundary matches
- Large legitimate file uploads to PHP apps (tune sc-bytes threshold)
level: critical
fields:
- c-ip
- cs-uri-stem
- c-useragent
- cs-method
- sc-bytes
- sc-status
```

### sigma_cve_2026_109618_response_marker.yml — Post-Exploitation Rule

*Detects successful code execution in the HTTP response body (requires WAF/proxy logging).*

```
title: CVE-2026-109618 PHP2Shell Successful Exploitation
id: b2e8f4a1-3c7d-5e9b-ad83-1f6e72345678
status: experimental
description: Detects successful RCE response markers (JACKALPOC or uid=)
in HTTP response body — confirms exploit succeeded.
tags:
- attack.execution
- attack.t1190
- cve.2026.109618
logsource:
category: proxy
detection:
selection:
cs-uri-stem|endswith: '.php'
cs-method: 'POST'
markers:
sc-body|contains:
- 'JACKALPOC'
- 'uid=0'
condition: selection and markers
falsepositives:
- None expected
level: critical
```

### sigma-cli Conversion Examples

*Convert to native SIEM query language on the command line:*

```
# To Splunk SPL
sigma convert -t splunk -p splunk_windows rule.yml
# To Microsoft Sentinel KQL
sigma convert -t microsoft365defender rule.yml
# To QRadar AQL
sigma convert -t qradar rule.yml
# To Elastic (EQL/Lucene)
sigma convert -t elasticsearch -p ecs_windows rule.yml
# To ArcSight CEF filter
sigma convert -t arcsight rule.yml
```

---

## MITRE ATT&CK; Mapping

| Tactic | Technique | ID |
|---|---|---|
| Initial Access | Exploit Public-Facing Application | T1190 |
| Execution | Exploitation for Client Execution | T1203 |
| Defense Evasion | Abuse Elevation Control Mechanism | T1548 |
| Discovery | System Information Discovery | T1082 |

---

*Blue-team / defensive use only. Tune byte-size thresholds (Detection 3) against your environment baseline before production deployment. Sigma rules validated against sigma-core schema. MITRE ATT&CK;® is a registered trademark of The MITRE Corporation.*